GRC 10ALYTICS JUNE 2026 COHORT

ASSIGNMENT

MEDICARE PLUS HOSPITAL CASE STUDY

NAME: MOYINOLUWA AREGBESOLA

INSTRUCTOR: VICTORIA OLUYORI

SUBMITTED: SATURDAY AUGUST 8, 2026

As a GRC Analyst and case study organization being Medicare Plus Hospital, I would be assessing two incidents regarding the PCI DSS payment system and HIPAA patient records. Medicare Plus Hospital is a healthcare facility that uses an Electronic Health Record (EHR) system, takes card payments, maintains patient medical and treatment data, and collaborates with outside suppliers for cloud, payment, and medical services. The goal of this assessment is to determine the compliance requirements applicable to the two incidents and to suggest workable solutions to close any gaps found.

1. Incident 1

PCI DSS payment system

Card payments are accepted by Medicare Plus through their online patient portal and at the front desk. The payment processor receives the cardholder's details and the scenario specifically deals with safeguarding and sending cardholder data. Because Medicare Plus manages cardholder data, PCI DSS is applicable. The PCI DSS requirements that are important to the payment environment and apply to this incident include:

a. **Network Security Controls**
   This applies to Medicare Plus as it safeguards online payment connections and the payment environment from unreliable networks.

b. **Secure Configurations**
   Avoid using default passwords or security settings provided by vendors and instead use secure configurations for payment systems.

c. **Protect Stored Data**
   If cardholder data is kept, minimize its retention and safeguard it with appropriate procedures such hashing, encryption, masking, or truncation.

d. **Protect Data in Transit**
   Encrypt cardholder information before sending it to the payment processor through open or public networks.

e. **Protect Against Malware**
   Maintain anti-malware systems and safeguard payment processing systems against harmful software.

f. **Secure Systems & Software**
   Use secure coding techniques and regular patching to keep payment apps and systems safe.

g. **Restrict Access**

Only employees with a valid business need should have access to cardholder information and payment systems.

h. **Identify & Authenticate**
To gain access to payment systems, they require strong credentials, distinct user identification, and suitable authentication controls.

i. **Restrict Physical Access**
Prevent unauthorized access to the devices, payment equipment, and any physical media that contains cardholder data.

j. **Log & Monitor Access**
To spot unusual activities, log and keep an eye on access to cardholder data and payment systems.

k. **Test Security Regularly**
Test security systems and procedures on a regular basis, including penetration testing and suitable vulnerability scanning.

l. **Support with Policy**
Conduct regular staff awareness training, incident response protocols, and information security policies.

MediCare Plus should protect Cardholder data by:

• Safeguard stored data: Use encryption, masking, truncation, or hashing to safeguard stored account data and minimize retention if cardholder data must be kept.

• Encrypt data in transit: When cardholder data goes over open or public networks from the online payment environment or reception to the payment processor, use effective encryption.

• Limit access: Using distinct accounts and suitable authentication, grant access to cardholder information and payment systems only to staff members who require it for their tasks.

• Maintain network security rules, secure setups, virus protection, and timely system/software updates to safeguard the payment environment.

• Monitor and test: Keep an incident-response procedure in place, test security controls on a regular basis, and log and monitor access.

• Encourage controls through policy and training: Create explicit information-security guidelines and educate staff members about their roles.

PCI DSS Compliance Gap and Recommended Control

Gap
The hospital implementing the necessary controls regarding its card-payment environment was not mentioned in the case study. This raises the possibility that cardholder data may be compromised while being stored, transmitted, accessed, or used in payment system activities.

Control recommendation
Medicare Plus should create a documented PCI DSS control program that addresses its payment environment. Systems in the cardholder data environment should be identified, the applicable PCI DSS criteria should be applied, access should be restricted, data in transit should be encrypted, stored cardholder data should be minimized, activity should be monitored, controls should be routinely tested, and staff awareness and supporting policies should be maintained.

2. Incident 2

HIPAA: Patient Records

A nurse found out that multiple staff members have access to patient records even though they don't require the data to complete their duties. The information being accessed is PHI (Protected Health Information) because patient records include personal health information. Personally identifiable health information (PHI) includes information such as diagnoses, treatment records, test findings, billing records, and insurance information that is stored or communicated by a covered entity or business associate. Also, the hospital uses its EHR system to maintain patient medical and treatment data. The HIPAA safeguards that apply to this scenario include:

a. **Administrative Safeguards**
Create guidelines and protocols for staff responsibilities, security management, training, and access control. Staff should be aware of their obligations to safeguard patient data and should only have access to records that are necessary for their jobs.

b. **Technical Safeguards**
To limit who can access electronic patient records, use authentication and access controls. User access should be restricted in accordance with staff work duties, and the EHR system should be protected with the proper controls.

c. **Physical Safeguards**
Physical access to workstations or other devices that are used to view patient records should also be restricted. This helps to prevent unauthorized people from using physical devices or desktops to access patient data.

d. **Organizational Requirements**
Adequate contractual and accountability systems should provide protections to third parties handling sensitive health information. This is necessary because Medicare Plus uses third party companies for cloud and medical services.

Medicare Plus can restrict access to patient records by doing the following:

• Use the minimum-necessary principle: Staff should only have access to patient data that is necessary for them to carry out their designated responsibilities.

• Make use of role-based access: Set up the EHR so that employment roles correspond with access rights. For instance, entire patient records shouldn't be immediately made available to staff members who don't require clinical information.

• Make use of distinct user accounts and authentication: In order to properly regulate and attribute access, each employee should have a unique account.

• Regularly evaluate access: When employees change roles or depart the company, management and system administrators should periodically examine user rights and eliminate any unnecessary access.

• Log and monitor access: To identify inappropriate or unusual conduct, keep audit logs of patient record access.

• Strengthen administrative controls by establishing explicit access guidelines, training staff, and holding staff members responsible for safeguarding patient data.

HIPAA Compliance Gap and Recommended Control

Gap

A number of employes have access to patient records even when the information is not required for their duties. This shows that the hospital's access control procedure is not effectively restricting access to patient data and that access is more extensive than is necessary.

Control recommendation

Medicare Plus should use the minimum-necessary approach and establish role-based access control within the EHR. Access should be granted in accordance with job duties, routinely checked, verified by individual user accounts, and tracked by audit logs. These technology controls should be supported by training for employees and administrative rules.

Medicare Plus should create an integrated GRC strategy that records compliance requirements, allocates control ownership, evaluates gaps, puts the necessary controls in place, and conducts routine assessments.
This will help improve accountability and compliance while helping the hospital in safeguarding patient and cardholder data.